EXECUTIVE SUMMARY & TECHNICAL REFERENCE

DOKUMENTASI SKILLSET KEAMANAN SIBER & DFIR

Katalog Lengkap Modul Custom Antigravity: Malware Analysis Sandbox, Digital Forensics (DFIR), Infrastructure Red Teaming, dan Triad Web Security Suite

7	6	100%	MITRE
SECURITY SKILLS	OTOMASI SCRIPT	STANDAR INDUSTRI	ATT&CK ALIGNED

Ringkasan Inti Portofolio:

Author: **Nafik** (Lead Security Researcher)

Dokumen resmi ini merangkum seluruh skillset keamanan siber modular tingkat lanjut yang dikembangkan oleh **Nafik** bersama asisten **Antigravity AI**. Dokumen ini menyorot secara mendalam modul yang diselesaikan kemarin: **Malware Triage & Quarantine Vault**, **Digital Forensics & Incident Response (DFIR)**, dan **Infrastructure Red Teaming (CEH)**, serta integrasinya dengan ekosistem pertahanan web terpadu.

Lead Security Researcher: Nafik (nafik@noname)**AI Engineering Pair:** Antigravity AI**Tanggal Terbit:** 4 November 2026

📑 1. Arsitektur & Taksonomi Modul Keamanan

Ekosistem pertahanan siber yang dibangun memadukan tiga pilar operasi: **Offensive Operations (Red Teaming)**, **Defensive Hardening (Blue Teaming)**, dan **Forensic Investigation & Malware Sandbox (DFIR)**. Seluruh modul didesain sesuai dengan kerangka kerja standar internasional: *NIST SP 800-86, NIST SP 800-115, ISO/IEC 27037, MITRE ATT&CK for Enterprise/Web,* dan *OWASP Top 10*.

Lead Researcher: Nafik **Role:** Cyber Threat & DFIR Architect **Workspace:** ANTIGRAVIT PROJECT

Daftar Isi Modul yang Dirangkum **7 MODUL TERPASANG**

Modul 1: Malware Triage, Quarantine Vault & DFIR Sandbox (`malware-triage`) Hal. 2

Modul 2: Digital Forensics & Incident Response Framework (`digital-forensics`) Hal. 3

Modul 3: Infrastructure Red Teaming & CEH Framework (`infra-red-teaming`) Hal. 4

Modul 4: Web Purple Teaming & Continuous Security Validation (`web-purple-teaming`) Hal. 5

Modul 5: Web Red Teaming (`web-red-teaming`) & Web Blue Teaming (`web-blue-teaming`) Hal. 6

Modul 6: Reverse Engineer Anything (`reverse-engineer-anything`) & Rekapitulasi CLI Hal. 7

Tabel Matriks Seluruh Skill Custom Keamanan

Nama Skill	Kategori	Standar Rujukan	Script Otomasi Utama	Fungsi Strategis
malware-triage	DFIR / SANDBOX	NIST SP 800-86, MITRE ATT&CK	`sandbox_cli.py`	Triage PE biner, isolasi XOR vault, dynamic behavioral monitoring, sinkhole C2, YARA.
digital-forensics	FORENSICS	NIST SP 800-86, ISO/IEC 27037	`forensic_triage.py`	Audit USBSTOR registri, file carving magic bytes, memori Volatility 3, Sigma YAML rules.
infra-red-teaming	RED TEAM	CEH v10/v11, NIST SP 800-115	`infra_audit.py`	Multi-threaded port scan, audit privesc lokal (Linux/Windows), SMB/SNMP enum, MITM.
web-purple-teaming	PURPLE TEAM	MITRE ATT&CK for Web, NIST CSF	`purple_orchestrator.php`	Orkestrasi Red + Blue, validasi deteksi kontinu, kalkulasi threat resistance score.
web-red-teaming	RED TEAM	OWASP Top 10:2021, ASVS v4.0	`audit_target.php`	Audit celah web (SQLi, XSS, CSRF, IDOR, SSRF), scan backdoor/webshell CVE.
web-blue-teaming	BLUE TEAM	CIS Benchmark, OWASP Defense	`hardening_checker.php`	Hardening server/CMS, security headers, WAF virtual patching, FIM file integrity.
reverse-engineer-anything	REA / BINARY	Reverse Engineering Artifacts	REA Toolset & Frida MCP	Decompilasi biner native/managed/JS, inspeksi simbol, instrumentasi dinamis Frida.

Karakteristik Desain: Seluruh modul dilengkapi instruksi mandiri di `SKILL.md`, tool otomatisasi (CLI), dan output terstruktur (HTML/JSON/YAML) yang dapat langsung diintegrasikan ke alur CI/CD maupun SIEM/EDR.

🦠 2. Deep Dive: Malware Triage & DFIR Sandbox

Modul `malware-triage` merupakan sistem otomatisasi analisis malware statis dan dinamis yang dilengkapi sistem karantina kriptografis (*Quarantine Vault*) dan telemetri jaringan berstandar NIST SP 800-86.

1. Analisis Statis & Deteksi Compiler `STATIC ENGINE`

- **Hashing Lengkap:** Menghasilkan MD5, SHA1, SHA256, dan Imphash (Import Hash) untuk pencocokan sampel biner sejenis.
- **Inspeksi PE & Proteksi OS:** Memeriksa mitigasi memori PE (ASLR, DEP/NX, SafeSEH, Authenticode Signature).
- **Compiler & Packer Detection:** Mendeteksi runtime GO, Rust, .NET CLR, serta packer seperti UPX dan Themida.

2. Analisis Entropi Shannon (0.0 - 8.0) `ENTROPY MATH`

Mengkalkulasi tingkat keacakan bit per seksi PE (`.text`, `.data`, `.rsrc`):

- `< 6.5`: Kode program normal / tidak terenkripsi.
- `6.5 - 7.2`: Terkompresi (contoh: UPX packing).
- `> 7.2`: Kuat dugaan payload terenkripsi (Ransomware / Packed).

3. Quarantine Vault (Isolasi XOR 0x5A) `AMAN & TERISOLASI`

Menetralkan biner berbahaya seketika dengan XOR stream mask (kunci `0x5A`) sehingga file tidak dapat dieksekusi oleh OS secara tidak sengaja, dicatat dalam encrypted ledger, serta dapat di-restore jika false positive.

4. Dynamic Behavior & C2 Sinkhole `SANDBOX ENGINE`

Eksekusi terkontrol dengan timeout, snapshot diff registri (Run/RunOnce persistence), pelacakan dropper di `%TEMP%` / `%APPDATA%`, dan simulasi penangkap lalu lintas C2 via sinkhole listener lokal.

Alur Kerja 4 Tahap Telemetri Jaringan NIST SP 800-86

Fase NIST	Aktivitas Eksekusi Sandbox	Artefak yang Dihasilkan
1. Collection	Mengaktifkan listener sinkhole port 80/53 lokal & buffer capture socket raw.	Raw Packet Capture Buffer & DNS requests log.
2. Examination	Dekode frame HTTP/DNS, parsing host header, user-agent, dan payload query.	Daftar domain C2 & struktur header HTTP tersangka.
3. Analysis	Pemetaan indikator C2 ke taktik MITRE ATT&CK (contoh: `T1071`, `T1105`).	Korelasi taktik & estimasi Threat Score (0 - 100).
4. Reporting	Penyusunan dashboard HTML visual interaktif dan aturan deteksi format YARA.	`report.html`, `report.json`, dan `rules.yar`.

Sintaks Penggunaan Perkakas CLI

```
# Analisis statis cepat:
python sandbox_cli.py "sample.exe"

# Analisis dinamis penuh + diff registri + sinkhole capture + karantina biner:
python sandbox_cli.py "sample.exe" --dynamic --timeout 15 --reg-diff --sinkhole --quarantine --outdir reports

# Restore sampel dari karantina:
python sandbox_cli.py --restore "sample.exe.vault" --restore-dir restored_samples
```

🕵️ 3. Deep Dive: Digital Forensics & Incident Response (DFIR)

Modul `digital-forensics` menyediakan prosedur operasional penyelidikan insiden pasca-eksploitasi berbasis standar **NIST SP 800-86** dan **ISO/IEC 27037**, menjamin keabsahan bukti (*Chain of Custody*) dari memori, disk, hingga jejak registri pengguna.

Aturan Urutan Volatilitas Bukti (Order of Volatility - RFC 3227)

Urutan akuisisi bukti wajib memprioritaskan data yang paling cepat hilang saat sistem dimatikan:

`Register / Cache CPU` → `Routing Table / ARP / Memori RAM` → `Temporary File System` → `Harddisk Fisik` → `Remote Log / SIEM`

1. Forensik Disk & File Carving — DISK ARTIFACTS

Mengekstrak berkas terhapus dari raw disk dump (`.raw`, `.dd`, `.001`, `.E01`) berdasarkan pencocokan *Magic Bytes*:

- **JPEG:** `FF D8 FF` → `FF D9`
- **PDF:** `25 50 44 46` (%PDF) → `25 25 45 4F 46` (%%EOF)
- **ZIP / DOCX:** `50 4B 03 04` → `50 4B 05 06`
- **Windows PE:** `4D 5A` (MZ)

2. Forensik Memori RAM (Volatility 3) — RAM ANALYSIS

Pemeriksaan dump RAM untuk mendeteksi ancaman tanpa berkas (*fileless malware*):

- `windows.pslist / pstree`: Struktur relasi induk-anak proses.
- `windows.malfind`: Menemukan injeksi shellcode VAD memori tersembunyi.
- `windows.netscan`: Mendeteksi koneksi jaringan aktif saat RAM dicapture.

3. Pelacakan Jejak Flashdisk & Media Penyimpanan (USBSTOR Forensics) — WINDOWS REGISTRY

Untuk membuktikan adanya pencurian data oleh orang dalam (*insider threat*), modul ini mengaudit jalur registri:

- `HKLM\SYSTEM\CurrentControlSet\Enum\USBSTOR`: Vendor ID, Product ID, Serial Number unik flashdisk.
- `HKLM\SYSTEM\CurrentControlSet\Enum\USB`: Riwayat hub USB dan peripheral yang pernah tersambung.
- `HKLM\SYSTEM\MountedDevices` & `STORAGE\Volume`: Rekonsiliasi Drive Letter (e.g. E:\, F:\) dan GUID volume.

Event Log Forensics (Windows Security Event IDs Kritis)

Event ID	Nama Aktivitas	Indikasi Ancaman / Analisis Forensik
4624	Successful Logon	Periksa *Logon Type*: Tipe 2 (Interactive/Fisik), Tipe 3 (Network SMB), Tipe 10 (Remote Desktop RDP).
4625	Failed Logon	Indikator serangan *Password Spraying* atau *Brute Force* berulang.
4688	Process Creation	Mencatat eksekusi perintah lengkap via `CommandLine` (wajib aktifkan audit policy).
7045	Service Installed	Indikator persistensi atau lateral movement (misal: PsExec membuat service baru).
1102	Audit Log Cleared	Tindakan anti-forensik oleh penyerang untuk menghapus jejak kejahatan.

Sintaks Eksekusi Skrip `forensic_triage.py`

```
# 1. Audit riwayat koneksi flashdisk (USBSTOR) dari registri lokal:
python forensic_triage.py --audit-usb

# 2. File carving: ekstrak berkas terhapus dari citra raw disk dump:
python forensic_triage.py --carve "disk_evidence.raw" --outdir carved_evidence

# 3. Generate template aturan deteksi format Sigma (YAML):
python forensic_triage.py --gen-sigma --title "Deteksi Ransomware Shadow Copy Deletion" --process "vssadmin.exe delete shad
ows"
```

⚔️ 4. Deep Dive: Infrastructure Red Teaming & CEH

Modul `infra-red-teaming` menerapkan metodologi pengujian penetrasi infrastruktur, jaringan, dan eskalasi hak akses sistem operasi berdasarkan standar **CEH (Certified Ethical Hacker)** dan **NIST SP 800-115**.

Alur 5 Fase Siklus Penyerangan CEH

Fase Penyerangan	Metodologi & Teknik Operasional	Pemetaan Taktik MITRE
1. Reconnaissance	OSINT publik, WHOIS, DNS Zone Transfer misconfiguration (`dig axfr`), crt.sh mapping.	`TA0043` (Reconnaissance)
2. Scanning & Enum	Stealth SYN scan, Firewall evasion (Xmas/Null/ACK), enumerasi SMB, RPC, SNMP.	`TA0007` (Discovery)
3. Gaining Access	MITM (ARP Spoofing, LLMNR Responder), eksploitasi layanan, eskalasi hak akses (PrivEsc).	`TA0001` / `TA0004` (Access / PrivEsc)
4. Maintaining Access	Pemasangan backdoor, persistence via Cron jobs, Windows Scheduled Tasks, Registry Run.	`TA0003` (Persistence)
5. Clearing Tracks	Anti-forensik, log tampering, pembersihan cache, Alternate Data Streams (ADS).	`TA0005` (Defense Evasion)

Teknik Pemindaian & Evasion Firewall NETWORK SCANNING

- **SYN Stealth Scan (`-sS`):** Standar de-facto; koneksi TCP tidak diselesaikan (diakhiri dengan paket RST) untuk menghindari logging pada aplikasi server.
- **TCP ACK Scan (`-sA`):** Digunakan untuk memetakan aturan firewall; mendeteksi apakah filter bertipe Stateful atau Stateless.
- **Inverse TCP (Null/Fin/Xmas):** Memanfaatkan celah RFC 793 pada sistem Unix; paket tanpa SYN/RST yang dikirim ke port tertutup dibalas RST, sedangkan port terbuka didiamkan.

Vektor Eskalasi Hak Akses (PrivEsc) SYSTEM EXPLOITATION

- **Linux Privilege Escalation:** Eksploitasi file berbiner SUID root tidak aman, sudoers misconfiguration (`sudo -l`), dan Linux Capabilities (e.g. `cap_setuid`).
- **Windows Token Manipulation:** Pemanfaatan privilege akun servis seperti `SeImpersonatePrivilege` menggunakan varian Potato (Juicy, Print, GodPotato) untuk eskalasi ke akun NT AUTHORITY\SYSTEM.

Deep Service Enumeration & Cracking PROTOCOL EXPLOITATION

- **SMB & NetBIOS (Port 139/445):** Menguji ketersediaan *Null Session* (koneksi `IPC$` tanpa otentikasi) untuk mencuri daftar user, password policy, dan share direktori anonim.
- **SNMP Enumeration (Port 161 UDP):** Melakukan MIB walking pada community string bawaan (`public` / `private`) untuk membocorkan konfigurasi routing dan nama software.
- **Man-in-the-Middle (MITM):** Melakukan keracunan cache ARP (ARP Spoofing) serta menangkap hash NetNTLMv2 via LLMNR/NBT-NS Poisoning menggunakan Responder.

Sintaks Eksekusi Skrip `infra_audit.py`

```
# 1. Scanning multi-threaded port & banner grabbing cepat:
python infra_audit.py --scan 192.168.1.1 --ports 21,22,80,443,445,3389

# 2. Audit otomatis vektor Local Privilege Escalation (LPE) pada host:
python infra_audit.py --audit-privesc

# 3. Uji kerentanan SMB Null Session & Anonymous Share pada target:
python infra_audit.py --smb-check 192.168.1.50
```

5. Integrasi Web Security Triad (Red, Blue, Purple)

Tiga modul web security yang telah terpasang beroperasi secara sinergis untuk menguji, memperkuat, dan memvalidasi ketahanan aplikasi web terhadap serangan dunia nyata.

Web Red Teaming (`web-red-teaming`) OFFENSIVE

Fokus: Pengujian penetrasi aplikasi web berdasarkan *OWASP Top 10:2021* dan *ASVS v4.0*.

- Deteksi injeksi SQLi, Cross-Site Scripting (XSS), IDOR, SSRF, dan CSRF.
- Pemindaian berkas sensitif dotfiles (`.env`, `.git`, database dump `.sql`).
- Pendeteksian webshell dan backdoor tersembunyi via skrip `scan_webshell_cve.php`.

Web Blue Teaming (`web-blue-teaming`) DEFENSIVE

Fokus: Penguatan sistem dan konfigurasi pertahanan berlapis (*Defense in Depth*).

- Penerapan Security Headers: Content Security Policy (CSP), HSTS, X-Frame-Options.
- Hardening direktori upload (mematikan eksekusi script PHP via konfigurasi server).
- Pengecekan hardening otomatis menggunakan skrip `hardening_checker.php`.

Web Purple Teaming (`web-purple-teaming`) - Continuous Validation ORKESTRATOR UTAMA

Modul Purple Team bertindak sebagai jembatan yang menjalankan pengujian triad terpadu. Menggunakan skrip `purple_orchestrator.php`, sistem menjalankan serangan etis (Red), menguji apakah kontrol pertahanan memblokirnya (Blue), dan menghitung **Threat Resistance Score** secara otomatis.

```
# Menjalankan Audit Triad Terpadu (Red + Blue + Purple Verification):
php purple_orchestrator.php --path="/path/to/project" --target-url="http://target:port"
```

Matriks Pemetaan Taktik MITRE ATT&CK for Web

Taktik MITRE	ID Teknik	Nama Teknik	Simulasi Red Team	Kontrol Defensif Blue Team	Status Target
Reconnaissance	`T1595`	Active Scanning	Scanning probe `.env`, `.git`	Blokir akses 403 Forbidden / 404	BLOCKED
Initial Access	`T1190`	Exploit Public App	Injeksi parameter SQLi / XSS	Sanitasi prepared statement & CSP	MITIGATED
Credential Access	`T1110`	Brute Force	Pengiriman form login berulang	Rate limiting 429 & CAPTCHA	BLOCKED
Persistence	`T1505.003`	Web Shell Drop	Unggah file berbahaya ke direktori media	Sandboxing direktori upload (NoExec)	BLOCKED
Defense Evasion	`T1036`	Masquerading	Ekstensi ganda `shell.php.jpg`	Validasi MIME riil & random file rename	MITIGATED

🔬 6. Reverse Engineer Anything (REA) & Katalog Perkakas

Modul `reverse-engineer-anything` melengkapi portofolio keamanan dengan kemampuan bedah biner lintas platform (Native x86/ARM, Android APK/DEX, .NET, Webpack/JavaScript bundles, hingga Firmware).

Kapabilitas Reverse Engineering — BINARY ANALYSIS

- **Decompilasi Biner Statis:** Ekstraksi kontrol alur (CFG), cross-references (xrefs), dan decompilasi fungsi menjadi pseudo-code.
- **Dynamic Instrumentation (Frida):** Hooking fungsi native dan managed saat biner berjalan, inspeksi argumen, dan trace return values.
- **Android APK & Firmware:** Unpack resource, decompile smali/DEX, inspeksi arsitektur library native (.so), dan ekstraksi filesystem firmware.

Dukungan Standar & Format — FORMAT SUPPORT

- **Format Eksekusi:** Windows PE, Linux ELF, macOS Mach-O.
- **Managed Languages:** .NET CLR assemblies, Go binaries, Rust binaries, Java bytecode.
- **Web & Runtime:** Electron ASAR packages, Minified JS bundles, WASM modules, SQLite database evidence.

Katalog Lengkap Skrip & Lokasi File Modul Keamanan

Skill Name	Lokasi File SKILL.md	Skrip Eksekutabel / Helper
malware-triage	`~/.gemini/config/skills/malware-triage/SKILL.md`	`malware-sandbox/sandbox_cli.py`
digital-forensics	`~/.gemini/config/skills/digital-forensics/SKILL.md`	`digital-forensics/scripts/forensic_triage.py`
infra-red-teaming	`~/.gemini/config/skills/infra-red-teaming/SKILL.md`	`infra-red-teaming/scripts/infra_audit.py`
web-purple-teaming	`~/.gemini/config/skills/web-purple-teaming/SKILL.md`	`web-purple-teaming/scripts/purple_orchestrator.php`
web-blue-teaming	`~/.gemini/config/skills/web-blue-teaming/SKILL.md`	`web-blue-teaming/scripts/hardening_checker.php`
web-red-teaming	`~/.gemini/config/skills/web-red-teaming/SKILL.md`	`web-red-teaming/scripts/audit_target.php` `web-red-teaming/scripts/scan_webshell_cve.php`
reverse-engineer-anything	`~/.gemini/config/skills/reverse-engineer-anything/SKILL.md`	Toolset REA & MCP Instrumentation Engine

Kesimpulan Eksekutif:
Kombinasi ketujuh modul ini menghadirkan kapabilitas *End-to-End Cyber Threat Lifecycle Management* bagi asisten AI Antigravity: mulai dari **Reconnaissance & Penetration Testing** (Red), **Defensive Hardening & Virtual Patching** (Blue), **Validation & Orchestration** (Purple), **Forensic Investigation & Timeline Carving** (DFIR), **Automated Sandbox & Quarantine** (Malware Triage), hingga **Binary Reverse Engineering** (REA).